

# Annexe 2 — Grille de recette de la phase de build

DOCUMENT

**Grille de recette**

PROMOTION

**Master 1**

## Sommaire

---

|                                                                |          |
|----------------------------------------------------------------|----------|
| <b>Annexe 2 — Grille de recette de la phase de build .....</b> | <b>3</b> |
| 1. Infrastructure .....                                        | 3        |
| 2. Services .....                                              | 3        |
| 3. Vulnérabilités et chaînes .....                             | 4        |
| 3.1 Quota global — à vérifier une seule fois .....             | 4        |
| 3.2 Par service vulnérable — une ligne par service (12) .....  | 4        |
| 3.3 Chaînes .....                                              | 5        |
| 4. Détection — Suricata et EveBox .....                        | 5        |
| 5. Documentation .....                                         | 5        |
| 6. Test final de disponibilité .....                           | 6        |

## Annexe 2 — Grille de recette de la phase de build

À dérouler **avant** la remise des livrables de phase 1. Chaque ligne est cochée par un membre du groupe qui **n’a pas** réalisé le service concerné.

### 1. Infrastructure

| #    | Contrôle                                                                            | Preuve attendue                          | OK                                  | Vérifié par |
|------|-------------------------------------------------------------------------------------|------------------------------------------|-------------------------------------|-------------|
| I-01 | Seuls les ports des services publiés sont redirigés par l’OPNsense                  | capture des règles de NAT                | <input checked="" type="checkbox"/> |             |
| I-02 | Chaque zone du CDC correspond à un réseau Docker distinct                           | <code>docker network ls + inspect</code> | <input checked="" type="checkbox"/> |             |
| I-03 | Les règles de filtrage sont documentées une à une                                   | export de la configuration               | <input checked="" type="checkbox"/> |             |
| I-04 | La règle terminale est un refus journalisé                                          | capture                                  | <input checked="" type="checkbox"/> |             |
| I-05 | Les accès distants demandés par le CDC fonctionnent                                 | connexion réussie                        | <input checked="" type="checkbox"/> |             |
| I-06 | Aucun conteneur n’est en <code>network_mode: host</code> ni <code>privileged</code> | <code>docker-compose.yml</code>          | <input checked="" type="checkbox"/> |             |
| I-07 | Aucun conteneur non prévu n’est attaché à deux réseaux                              | <code>docker network inspect</code>      | <input checked="" type="checkbox"/> |             |
| I-08 | La pile complète se relève après <code>docker compose down &amp;&amp; up -d</code>  | horodatage du test                       | <input checked="" type="checkbox"/> |             |
| I-09 | La configuration et les jeux de données sont versionnés et rejouables               | dépôt ou archive                         | <input checked="" type="checkbox"/> |             |

### 2. Services

Une ligne **par service** de la tranche ferme du CDC.

| #    | Contrôle                                                | Preuve attendue                                  | OK                                  | Vérifié par |
|------|---------------------------------------------------------|--------------------------------------------------|-------------------------------------|-------------|
| S-01 | Le service est déployé et se relève seul                | <code>docker compose ps</code> après redémarrage | <input checked="" type="checkbox"/> |             |
| S-02 | Le nom du conteneur respecte la convention du socle     | <code>docker compose ps</code>                   | <input checked="" type="checkbox"/> |             |
| S-03 | Le service est joignable depuis son réseau d’usage      | requête réussie                                  | <input checked="" type="checkbox"/> |             |
| S-04 | Le service est injoignable depuis les réseaux interdits | balayage <code>nmap</code> négatif               | <input checked="" type="checkbox"/> |             |

|      |                                                              |                               |   |
|------|--------------------------------------------------------------|-------------------------------|---|
| S-05 | Le service est habillé aux couleurs de l'entreprise          | capture d'écran               | ☒ |
| S-06 | Les jeux de données exigés par le CDC sont présents          | comptage en base ou à l'écran | ☒ |
| S-07 | Les comptes de l'annexe du CDC existent avec les bons droits | liste des comptes             | ☒ |

### 3. Vulnérabilités et chaînes

#### 3.1 Quota global — à vérifier une seule fois

| #    | Contrôle                                                                        | Preuve attendue                                       | OK | Vérifié par |
|------|---------------------------------------------------------------------------------|-------------------------------------------------------|----|-------------|
| Q-01 | 12 services portent une vulnérabilité issue de Vulhub                           | inventaire du document pédagogique                    | ☒  |             |
| Q-02 | <b>Exactement 3</b> d'entre eux sont exploitables avec les seuls accès initiaux | balayage + tests depuis l'extérieur                   | ☒  |             |
| Q-03 | Aucun quatrième service n'est exploitable depuis l'extérieur                    | revue des ports publiés et des services publiés sains | ☒  |             |
| Q-04 | Les 9 autres exigent un pivot pour être atteintes                               | matrice <code>nmap</code> du guide builder            | ☒  |             |
| Q-05 | Les 12 flags sont placés et référencés dans la matrice                          | <i>annexe 3 — Matrice des flags</i>                   | ☒  |             |

#### 3.2 Par service vulnérable — une ligne par service (12)

| #    | Contrôle                                                                         | Preuve attendue                            | OK | Vérifié par |
|------|----------------------------------------------------------------------------------|--------------------------------------------|----|-------------|
| V-01 | L'exploit fonctionne <b>depuis l'extérieur du SI</b> (ou depuis le niveau prévu) | commande + sortie                          | ☒  |             |
| V-02 | L'exploit a été rejoué par un autre membre du groupe                             | nom du vérificateur                        | ☒  |             |
| V-03 | Le niveau annoncé (N1/N2/N3) correspond à l'accessibilité réelle                 | matrice <code>nmap</code> du guide builder | ☒  |             |
| V-04 | Le flag est en place, lisible par le chemin prévu et survit à un redémarrage     | sortie de l'exploit                        | ☒  |             |
| V-05 | Le flag n'est <b>pas</b> accessible sans exploitation                            | test négatif documenté                     | ☒  |             |
| V-06 | Le flag provient du CSV fourni                                                   | comparaison avec le CSV                    | ☒  |             |
| V-07 | Les modifications apportées à l'image Vulhub sont documentées                    | <code>diff</code> avec l'original          | ☒  |             |

### 3.3 Chaînes

| #    | Contrôle de chaîne                                      | Preuve attendue                  | OK | Vérifié par |
|------|---------------------------------------------------------|----------------------------------|----|-------------|
| C-01 | Chaîne 1 rejouée de bout en bout, N1 → N2 → N3          | journal de la démonstration      | ☒  |             |
| C-02 | Chaîne 2 rejouée de bout en bout, N1 → N2 → N3          | journal de la démonstration      | ☒  |             |
| C-03 | Les deux chaînes ne partent pas du même N1              | schéma des chaînes               | ☒  |             |
| C-04 | Chaque maillon fournit l'information menant au suivant  | capture de l'information trouvée | ☒  |             |
| C-05 | Aucun raccourci ne permet d'atteindre un N3 directement | balayage depuis la DMZ           | ☒  |             |

## 4. Détection — Suricata et EveBox

| #    | Contrôle                                                                       | Preuve attendue                  | OK | Vérifié par |
|------|--------------------------------------------------------------------------------|----------------------------------|----|-------------|
| D-01 | EveBox est accessible et remonte des événements                                | capture de l'interface           | ☒  |             |
| D-02 | Le trafic vers les services publiés apparaît dans la sonde                     | événements horodatés             | ☒  |             |
| D-03 | Les règles du groupe sont dans <code>/etc/suricata/rules/tp-local.rules</code> | contenu du fichier               | ☒  |             |
| D-04 | Les <code>sid</code> des règles du groupe commencent à 9000001                 | contenu du fichier               | ☒  |             |
| D-05 | Suricata recharge sans erreur après ajout des règles                           | sortie du test de configuration  | ☒  |             |
| D-06 | Chaque règle a été déclenchée au moins une fois en test                        | capture de l'alerte dans EveBox  | ☒  |             |
| D-07 | Les journaux applicatifs des conteneurs sont consultables                      | <code>docker compose logs</code> | ☒  |             |

## 5. Documentation

| #    | Contrôle                                                                  | OK | Vérifié par |
|------|---------------------------------------------------------------------------|----|-------------|
| P-01 | Le document pédagogique contient le schéma réseau complet                 | ☒  |             |
| P-02 | L'inventaire liste toutes les machines et tous les services               | ☒  |             |
| P-03 | Chaque service vulnérable a sa fiche (CVE, niveau, exploit, flag, preuve) | ☒  |             |
| P-04 | Les deux chaînes sont schématisées                                        | ☒  |             |

|      |                                                                                           |   |
|------|-------------------------------------------------------------------------------------------|---|
| P-05 | Tous les comptes et accès sont listés                                                     | ☒ |
| P-06 | La répartition nominative des travaux est présente                                        | ☒ |
| P-07 | Le document attaquant ne contient <b>que</b> le périmètre publié et les accès de test     | ☒ |
| P-08 | Le document attaquant ne mentionne aucune CVE, aucun plan d'adressage interne, aucun flag | ☒ |
| P-09 | La matrice des flags est complète et cohérente avec le CSV fourni                         | ☒ |

## 6. Test final de disponibilité

| #    | Contrôle                                                                                          | OK |
|------|---------------------------------------------------------------------------------------------------|----|
| F-01 | <code>docker compose down</code> puis <code>docker compose up -d</code> sur l'ensemble de la pile | ☒  |
| F-02 | 10 minutes après, tous les services publiés répondent                                             | ☒  |
| F-03 | Les deux chaînes sont encore exploitables après redémarrage                                       | ☒  |
| F-04 | Tous les flags sont toujours en place                                                             | ☒  |
| F-05 | La sonde reçoit à nouveau du trafic et les règles locales sont chargées                           | ☒  |